

보도시점 2025. 1. 23.(목) 12:00
(2025. 1. 23.(목) 석간)

배포 2025. 1. 22.(수) 18:30

개인정보위, 안전조치 의무 위반 2개 사업자에 19억 4,280만 원 과징금·과태료 부과

- 크리덴셜 스테핑 공격 방지를 위한 이용자 인증(ID·PW 등) 보안 철저 및 이상행위 탐지·차단 조치 강화 당부

개인정보보호위원회(위원장 고학수, 이하 ‘개인정보위’)는 1월 22일(수) 제2회 전체회의를 열고, 「개인정보 보호법」(이하 ‘보호법’)을 위반한 SK스토아(주)와 (주)동행복권에 대해 총 19억 4,280만 원의 과징금 및 과태료를 부과하고 공표 명령하기로 의결하였다.

※ SK스토아(주) : 과징금 14억 3,200만 원, 과태료 300만 원, 공표 명령

(주)동행복권 : 과징금 5억 300만 원, 과태료 480만 원, 공표 명령

개인정보위는 개인정보 유출 신고에 따라 조사한 결과, 이들 사업자는 「개인정보 보호법」에 따른 안전조치 의무를 소홀히 한 것으로 확인되었으며, 구체적인 위반 내용과 처분 결과는 다음과 같다.

< SK스토아(주) >

SK스토아(주)는 온라인 쇼핑몰 및 TV홈쇼핑을 운영하는 사업자로, 온라인 쇼핑몰인 ‘SK스토아’ 웹사이트에 신원 미상의 해커가 ’23. 11. 14. ~ 11. 21. 동안 ‘크리덴셜 스테핑*(Credential Stuffing)’ 공격 방법으로 침입해 12만 5천여 명의 개인정보가 유출되었다.

- * 공격자가 어떤 방법을 통해 계정·비밀번호 정보를 취득한 후 다른 사이트에서도 이를 동일하게 사용하여 성공할 때까지 로그인을 시도하는 대입 공격으로, 로그인 시도 횟수와 로그인 실패율이 급증하는 특징을 보임

개인정보위 조사 결과에 따르면, 위 기간동안 해커는 ‘SK스토아’ 웹사이트에 국내외 14개 아이피(IP) 주소를 통해 1초당 최대 372회, 총 4,400만 번 이상 대규모로 로그인을 시도*하였고, 이 중 12만 5천여 개의 회원 계정으로 로그인에 성공하여 개인정보가 포함된 웹페이지에 접근한 것으로 확인되었다.

* 공격 기간의 일평균 로그인 시도 건수는 평시 대비 1,092배 높은 것으로 확인됨

< 개인정보 유출사고 개요 >



이는, SK스토아(주)가 특정 IP 주소에서 대량의 반복적인 로그인 시도 등 비정상적인 접속 시도를 방지하기 위한 침입 탐지·차단 대책 및 이상행위 대응 등 안전조치의무를 소홀히 하였기 때문인 것으로 밝혀졌다.

한편, 조사 과정에서 ‘SK스토아’ 일부 웹페이지에서는 이용자의 비밀번호가 암호화 조치 되지 않은 평문 상태로 송·수신된 사실도 추가적으로 확인되었다.

이에 따라 개인정보위는 SK스토아(주)에 총 14억 3,200만 원의 과징금과 300만 원의 과태료를 부과하고, 사업자 누리집(홈페이지)에 그 사실을 공표하도록 명령하였다.

유출사고 발생 이후, SK스토아(주)는 비정상적인 로그인 시도에 대한 보안 정책을 적용·강화하는 등 위반사항을 시정하는 한편, 향후 유사 피해가 재발하지 않도록 유출된 이용자 대상 계정 초기화, 기존의 로그인 방식 변경 등 조치를 취하였다.

< (주)동행복권 >

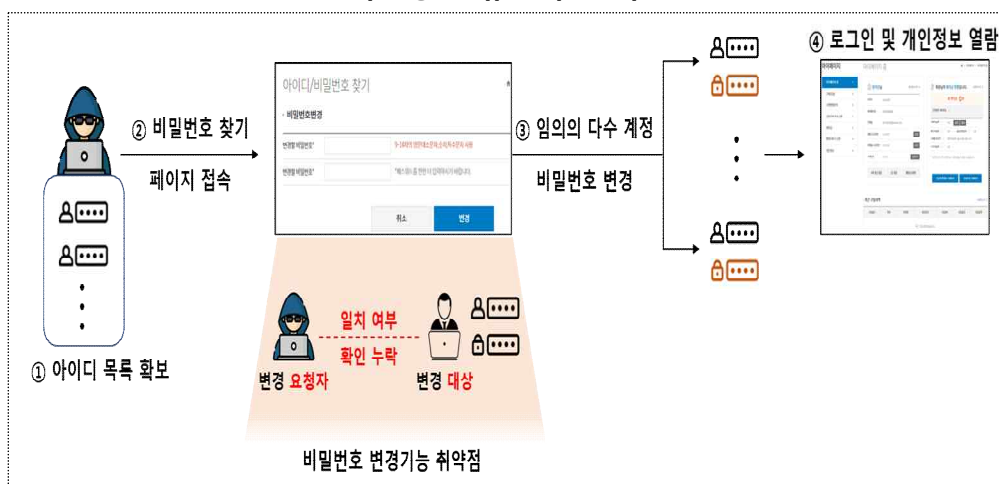
(주)동행복권은 복권위원회로부터 복권 발행·관리 및 판매 등의 업무를 위탁받아 처리하는 사업자로, '23. 11. 4. ~ 11. 5. 신원 미상의 해커가 복권 통합포털인 '동행복권' 웹사이트의 회원 아이디(ID) 목록을 사전에 확보하고, 회원 비밀번호 변경 기능에 존재하는 보안 취약점*을 악용하여 다른 계정의 비밀번호를 임의 변경한 후 로그인에 성공했다. 이로써 약 75만 명의 개인 정보가 유출되었다.

* 비밀번호 변경 페이지에서 인증받은 아이디가 아닌 다른 아이디로 입력을 조작하면 조작한 아이디의 비밀번호가 변경되는 취약점이 존재함

이는 (주)동행복권이 '비밀번호 변경 기능' 설계·구현 시 이용자 인증 관련 보안 취약점에 대해 점검·개선 조치를 소홀히 하였으며, 해커의 과도한 접속 시도 등 이상행위를 탐지하고 차단하는 등의 안전조치가 미흡했기 때문으로 밝혀졌다.

이에 따라 개인정보위는 (주)동행복권에 총 5억 300만 원의 과징금과 480만 원의 과태료를 부과하고, 사업자 누리집에 그 사실을 공표하도록 명령하였다.

< 개인정보 유출사고 개요 >



유출사고 발생을 인지한 즉시 (주)동행복권은 누리집을 임시 폐쇄하고, 계정 비밀번호 초기화 및 취약한 소스코드 수정 등 위반사항을 시정하는 한편, 향후 유사 피해가 재발하지 않도록 비정상적인 접속시도에 대한 탐지·차단을 강화하는 등의 조치를 취하였다.

개인정보위는 최근 크리덴셜 스테핑 등 해킹공격이 빈번하게 발생하는 만큼 이상행위에 대한 침입 탐지·차단 조치 등 보안대책을 강화하고, 이용자 인증 관련 취약점 점검 등에도 각별한 주의를 기울일 것을 당부했다.

[붙임] 사업자별 위반 및 시정조치 내역

담당 부서 <총괄>	개인정보보호위원회 조사2과	책임자	과 장	이정은 (02-2100-3121)
		담당자	조사관	허재형 (02-2100-3129)
		담당자	조사관	장석인 (02-2100-3157)
<공동>	한국인터넷진흥원 플랫폼조사팀	책임자	팀 장	문봉주 (061-820-1496)
		담당자	주 임	나정용 (061-820-1461)
		담당자	주 임	한미정 (061-820-1355)



붙임

사업자별 위반 및 시정조치 내역

< 피심인별 시정조치(안) >

연번	피심인 명	위반 내용	위반조항	시정조치(안)
1	SK스토아(주)	• 안전조치의무 (접근통제, 암호화)	보호법 §29	• 과징금 14억 3,200만 원 • 과태료 300만 원 • 공표명령
2	(주)동행복권	• 안전조치의무 (접근통제, 암호화)	보호법 §29	• 과징금 5억 300만 원 • 과태료 480만 원 • 공표명령